INFORMATION SECURITY RISK ASSESSMENT PROCESS

SOP-010 | Standard Operating Procedure | Issued under POL-010

Document ID: SOP-010
Version: 1.0 — DRAFT
Parent Policy: POL-010 — Information Security Risk Policy
Classification: Internal Use
Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Information Security Risk Assessment Process
Document ID	SOP-010
Version	1.0 — DRAFT
Parent Policy	POL-010 — Information Security Risk Policy
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-007 (Change Management), POL-008 (Access Control), POL-011 (Business Continuity), POL-012 (Incident Response), POL-013 (Third Party), POL-014 (Audit Trail), SOP-003 (Data Integrity — DIRA), SOP-004 (Privacy — DPIA), SOP-005 (System Classification), SOP-006 (Validation), SOP-007 (Change Management), SOP-013 (Vendor Risk), EXC-001 (Exception Management), RACI-001
Owner	Information Security Manager
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

NOTE: The 5×5 likelihood × impact matrix in Section 4 is identical to the matrix used in SOP-003 (DIRA) and SOP-004 (DPIA). This is intentional — all risk scores across the IMF suite are directly comparable. A High risk identified in a DIRA assessment and a High risk in the IS Risk Register represent the same level of organisational concern and the same response obligation.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the Information Security Risk Assessment (ISRA) methodology used by [Company Name] to identify, assess, treat, and monitor information security risks. It operationalises POL-010 by establishing the specific steps, scoring criteria, treatment decision framework, Risk Register structure, and governance reporting cadence.

The ISRA is both a stand-alone annual exercise and a continuous process. System-level risk assessments are conducted pre-deployment for new Tier 1/2 and GxP systems. Trigger-based assessments are conducted after material incidents, regulatory changes, and significant organisational changes. The annual enterprise-wide ISRA consolidates all sub-registers — DIRA, DPIA, vendor risk, and system-level assessments — into the unified IS Risk Register that is reported to the Board.

2. Scope

This SOP applies to all information security risk assessments at [Company Name], including:

- The annual enterprise-wide Information Security Risk Assessment (ISRA)
- System-level risk assessments conducted as part of new system deployment or material change (SOP-006, SOP-007)
- Trigger-based assessments following material incidents (SOP-012, SOP-015), regulatory changes, third-party failures, or material organisational changes
- Vendor risk assessments (conducted under SOP-013, feeding results into the IS Risk Register)

Domain-specific risk processes that use the same methodology but produce separate registers — DIRA (SOP-003) and DPIA (SOP-004) — are sub-registers of the IS Risk Register. Their outputs are consolidated into the IS Risk Register quarterly per Section 7.

3. Roles and Responsibilities

Role	Responsibility
CISO	ISRA process owner. Approves IS Risk Register entries. Presents risk posture to ISSG and Board. Signs risk acceptance decisions for High and Critical risks. Co-signs GxP risk acceptance with Compliance / QA.
Information Security Manager	Leads ISRA execution. Maintains IS Risk Register. Coordinates with system owners and domain risk leads. Produces quarterly risk report for ISSG.

Role	Responsibility
Risk Owner	The System Owner or business process owner accountable for a specific risk. Makes risk treatment decisions within their domain. Reports treatment progress to Information Security. Distinct from Control Owner — the Risk Owner decides; the Control Owner implements.
Control Owner	The technical or operational owner responsible for implementing the agreed risk treatment. Typically Data Custodian (IT) for infrastructure risks or the relevant system team. Reports control status to Information Security.
Compliance / QA	Co-approves risk treatment decisions for GxP risks. Reviews DIRA inputs to IS Risk Register. Assesses regulatory notification obligations for Critical GxP risks.
DPO	Co-approves risk treatment decisions for privacy risks. Reviews DPIA inputs to IS Risk Register. Provides GDPR regulatory risk context.
ISSG	Reviews IS Risk Register summary quarterly. Challenges risk acceptance decisions. Recommends Board escalation for Critical risks. Approves annual ISRA output.

4. Risk Scoring Matrix

All risk scores use the 5×5 likelihood × impact matrix. This matrix is identical to the one used in SOP-003 (DIRA) and SOP-004 (DPIA) — scores are directly comparable across all risk domains.

4.1 Likelihood Scale

Score	Label	Definition
5	Almost Certain	Expected to occur in the current year. Known active threat, known vulnerability, observed in similar organisations.
4	Likely	Could occur in the current year. Strong indicators present. Threat actor known to target this sector.
3	Possible	Might occur within 1–2 years. Some indicators present. General sector exposure.
2	Unlikely	Unlikely in the next 2–5 years. Low threat activity. Controls largely effective.
1	Rare	Expected less than once in 5 years. Very low threat. Strong controls in place.

4.2 Impact Scale

Score	Label	Definition
5	Catastrophic	Regulatory: Critical finding leading to product recall, clinical hold, or regulatory agency action. Financial: material loss >£5M or >5% annual revenue. Reputational: sustained media coverage, patient harm, or loss of operating licence.
4	Major	Regulatory: significant finding requiring formal response and remediation plan. Financial: £500k–£5M. Reputational: sector-wide attention, regulator correspondence, customer attrition.
3	Moderate	Regulatory: reportable event requiring notification. Financial: £50k–£500k. Reputational: contained adverse coverage, limited customer impact.
2	Minor	Regulatory: internal finding, no external notification required. Financial: £5k–£50k. Reputational: minimal external visibility.
1	Negligible	No regulatory, financial, or reputational consequence outside the organisation.

4.3 Risk Rating and Response

Score	Rating	Colour	Response Obligation	GxP Risk Additional Requirement
20–25	Critical	Red	5-business-day treatment plan. CISO and Board notified. GxP system may not operate for the risk scope until treatment in place. Escalated to ISSG immediately.	Compliance / QA co-signs treatment plan. Regulatory notification assessment within 24 hours.
10–19	High	Amber	30-business-day treatment plan with weekly progress reporting. CISO approval required for risk acceptance. ISSG notified at next meeting.	Compliance / QA co-signs treatment plan. Treatment must reduce to Medium or below within 90 days or Board notification required.
5–9	Medium	Yellow	90-business-day treatment plan. Quarterly progress review. Information Security Manager approval required for risk acceptance.	Information Security Manager + Compliance / QA review. Treatment plan with target date.
2–4	Low	Green	Document and monitor. Annual review minimum. No formal treatment plan required unless Risk Owner requests.	Standard treatment review. No escalation required.
1	Very Low	Grey	Accept and monitor. No action required beyond Risk Register entry.	Accept. Note in DIRA if applicable.

IMPORTANT: Critical and High GxP data integrity risks cannot be accepted under POL-010 risk appetite — they must be treated. A risk acceptance decision for a Critical or High GxP risk is not within the CISO's authority alone: it requires Compliance / QA Director co-signature and Board notification. In practice, such a decision signals that [Company Name] is operating a GxP system with a known critical data integrity risk — a position that is untenable for a regulated entity.

5. Risk Assessment Process

Step 01	**Scope Definition** Before any risk assessment begins, the scope is agreed and documented: Annual ISRA scope: — All Tier 1 and Tier 2 systems in the System Register (SOP-005) — All GxP systems regardless of tier — All SOX ITGC systems — All systems with GDPR or HIPAA flags where a material change has occurred since last assessment — All open risks from the prior year ISRA (carried forward for re-assessment) — All risks from DIRA (SOP-003), DPIA (SOP-004), and vendor risk (SOP-013) sub-registers	Responsible **CISO / Information Security Manager**

	System-level ISRA scope (pre-deployment or change-driven): — The specific system and its data flows — Infrastructure components in the validated scope (GxP systems) — Integrations with other systems — scope boundary explicitly defined Scope documented in the ISRA Initiation Record, approved by CISO before assessment activities begin.	
Step 02	**Asset and Data Flow Inventory** Inputs from existing registers are consolidated — not re-collected from scratch: — System Register (SOP-005): all in-scope systems, their tier, regulatory flags, and System Owner — Asset Register (SOP-001 / WI-001): data assets held by each system and their sensitivity tier — DIRA Register (SOP-003): GxP data flows and existing data integrity risks — DPIA outputs (SOP-004): personal data processing risks — Vendor risk register (SOP-013): third-party risks affecting in-scope systems Gaps in the registers — systems not classified, data assets without a sensitivity assessment — are themselves findings raised as Low or Medium risks in the ISRA output, with the register update as the treatment action. Output: consolidated asset and data flow inventory for the ISRA scope. Reviewed by Information Security Manager before proceeding.	Responsible **Information Security Manager**
Step 03	**Threat and Vulnerability Identification** Threats and vulnerabilities are identified from four sources, applied to each asset in the inventory: 1. Threat intelligence: current threat landscape for the pharmaceutical / life sciences sector. Sources include ISAC feeds, CISA advisories, vendor security bulletins, and the organisation's own incident history. 2. Vulnerability data: output from the vulnerability management programme — current CVE findings against in-scope systems, penetration test findings open from the previous 12 months, configuration review findings. 3. Control gap analysis: comparison of required controls per POL-008, POL-009, POL-014 against confirmed implemented controls. Gaps are vulnerabilities. 4. Sub-register inputs: DIRA findings (SOP-003), DPIA findings (SOP-004), and vendor risk findings (SOP-013) that represent threats or vulnerabilities in scope. Each identified threat-vulnerability pair is recorded in the risk assessment worksheet: asset, threat, vulnerability, potential consequence.	Responsible **Information Security Manager / Risk Owner per system**
Step 04	**Risk Scoring** For each threat-vulnerability pair, the assessor scores: Inherent risk: Likelihood × Impact without any controls in place (worst case) Control effectiveness: assessment of how effectively existing controls reduce likelihood and/or impact (High / Medium / Low / None) Residual risk: Likelihood × Impact with existing controls applied Scoring principles: — Score the residual risk conservatively — if there is doubt about control effectiveness, score as if the control provides less assurance — For GxP risks: the impact of a data integrity failure must account for the regulatory consequence (patient safety, product release integrity) — not just the IT consequence — For risks where the control is a procedure rather than a technical control: score control effectiveness as Low unless the procedure has been tested or audited recently — Cross-system risks (e.g., a	Responsible **Information Security Manager / Risk Owner**

	vulnerability that affects multiple systems): scored once at the aggregate level with a note of all affected systems Risk scores are reviewed by the Information Security Manager for consistency before proceeding to treatment.	
Step 05	**Risk Treatment Selection** For each scored risk, the Risk Owner selects a treatment from the four options: Mitigate: implement controls to reduce likelihood or impact to an acceptable residual risk level. The most common treatment. Requires a specific control, a named Control Owner, and a target date. Accept: formally document that the residual risk is within risk appetite and no additional treatment is required. Requires approval per Section 4.3 (by risk rating). GxP Critical/High risks cannot be accepted. Transfer: shift the financial consequence to a third party (typically cyber insurance). Does not reduce likelihood or impact — only transfers the financial consequence. The underlying risk remains in the register. Avoid: eliminate the activity or asset that creates the risk. Appropriate when the risk cannot be reduced to acceptable levels and the activity is not essential. Not always feasible for GxP systems in operational use. Treatment decisions are recorded in the Risk Register entry. Risk Owners may not select 'Accept' for risks above their approval authority — the risk is escalated to the appropriate level before treatment selection is confirmed.	Responsible **Risk Owner / Information Security Manager / CISO**
Step 06	**Risk Register Entry** Each assessed risk is entered in the IS Risk Register with the following mandatory fields: — Risk ID: ISR-YYYY-NNN (sequential within calendar year) — Risk title and description — Asset(s) affected — system ID from System Register — Regulatory flags: GxP / SOX / GDPR / HIPAA — Threat and vulnerability description — Inherent likelihood score / inherent impact score / inherent risk score — Existing controls description — Control effectiveness assessment — Residual likelihood score / residual impact score / residual risk score and rating — Risk Owner (named individual) — Treatment decision: Mitigate / Accept / Transfer / Avoid — Treatment plan: specific actions, Control Owner(s), target dates (for Mitigate and Avoid treatments) — Acceptance rationale and approver (for Accept decisions) — Sub-register reference (DIRA / DPIA / vendor risk entry reference, if applicable) — Date raised, date last reviewed, next review date — Status: Open / In Treatment / Accepted / Closed Risk Register entries are retained for 7 years from the date the risk is closed per POL-002.	Responsible **Information Security Manager**
Step 07	**ISRA Report and Approval** On completion of the ISRA, the Information Security Manager produces the ISRA Report: — Executive summary: risk posture, key findings, material changes from prior year — Risk Register summary: breakdown by rating (Critical/High/Medium/Low), by domain, and by regulatory flag — New risks identified this cycle — Risks closed since last cycle (with closure evidence) — Risks where treatment has not progressed —	Responsible **Information Security Manager / CISO / ISSG**

escalation recommendations — Top 10 residual risks with treatment status — Sub-register alignment: DIRA, DPIA, and vendor risk confirmations ISRA Report approval: 1. Information Security Manager finalises draft 2. CISO reviews and approves 3. ISSG reviews at next meeting 4. Board / Audit Committee receives annual risk posture summary Annual ISRA Report is completed within 60 days of the ISRA scope initiation date.

6. System-Level Risk Assessments

System-level risk assessments are conducted as a mandatory input to SOP-006 (validation) for new GxP systems and Tier 1 systems, and as part of the SOP-007 change impact assessment for material changes. They use the same methodology as the annual ISRA but are scoped to the specific system.

Trigger	Scope	Integration Point	Output
New Tier 1 or GxP system deployment	System and its direct integrations. Infrastructure components in validated scope.	SOP-006 Step 4 (Risk Assessment) — system-level ISRA is a mandatory VMP deliverable	System Risk Assessment Report filed in VMF. Residual risks above Medium entered in IS Risk Register.
Major change to Tier 1 or GxP system	Changed component(s) and affected data flows.	SOP-007 GxP Validation Impact Assessment — risk assessment updates the system-level risk profile	Risk Assessment Update filed in VMF (change record section). New or elevated risks entered in IS Risk Register.
Material security incident	Affected systems and data flows. Root cause vulnerability.	SOP-012 Post-Incident Review — risk assessment determines whether the incident reveals systemic risk	Post-incident risk entries in IS Risk Register. ISRA scope updated if systemic.
Regulatory change affecting GxP or privacy	All systems with the relevant regulatory flag.	Annual ISRA cycle or out-of-cycle trigger assessment	Regulatory risk entries in IS Risk Register. Compliance / QA notified.
New third-party engagement (Tier A/B)	Systems the vendor will access. Data flows the vendor will interact with.	SOP-013 vendor risk assessment — outputs fed into IS Risk Register	Vendor risk entries in IS Risk Register linked to SOP-013 vendor assessment record.

7. Risk Register Governance

The IS Risk Register is a living document — it is not an annual snapshot. Risks are added, updated, and closed continuously. The governance cadence ensures the register reflects the current risk posture at all times.

Cadence	Scope	Owner	Output
Monthly	All Critical and High risks — treatment progress confirmed. New risks added since last cycle reviewed. CISO notified of any Critical risk where treatment has not progressed.	Information Security Manager	Monthly risk status update. CISO briefing for Critical/High risks.
Quarterly	Full Risk Register review. Sub-register alignment (DIRA, DPIA, vendor risk). Open exceptions from EXC-001 that have created IS risks reviewed. ISSG risk summary prepared.	Information Security Manager + CISO	ISSG risk summary report. Register updated for all reviewed entries.
Annually	Full ISRA cycle per Section 5. Board risk posture report. Prior year closed risks archived.	CISO + ISSG	ISRA Report. Board risk posture summary. Archived closed risk entries.
On trigger	Per Section 6 triggers — material incident, regulatory change, new system, major change, new Tier A/B vendor.	Information Security Manager	New or updated risk entries. CISO notification if Critical/High.

7.1 Sub-Register Alignment

Quarterly, Information Security Manager confirms alignment between the IS Risk Register and the three domain sub-registers:

- DIRA Register (SOP-003): all open DIRA findings with a risk score of Medium or above are reflected in the IS Risk Register as GxP data integrity risks. The DIRA register ID is referenced in the IS Risk Register entry.
- DPIA Register (SOP-004): all DPIA findings with a residual risk of High or above are reflected in the IS Risk Register as privacy risks. The DPIA reference number is recorded in the IS Risk Register entry.
- Vendor risk register (SOP-013): all vendor risk findings for Tier A/B vendors are reflected in the IS Risk Register. Vendor risk entries are linked to the SOP-013 vendor assessment record.

Misalignment — a sub-register finding with no corresponding IS Risk Register entry — is itself a risk register gap finding, raised at ISSG.

8. Risk Closure

A risk is closed when one of the following conditions is met and confirmed by the Information Security Manager:

- Mitigate treatment complete: the treatment controls have been implemented and tested. Residual risk score re-assessed and confirmed to have reduced to Low or Very Low. Control Owner confirms implementation. Information Security Manager confirms effectiveness.
- Risk no longer applicable: the asset or process that created the risk has been decommissioned or substantially changed such that the risk no longer exists. System Owner confirms. Risk Register entry updated with closure rationale.
- Accepted risk — no change: for formally accepted risks, the entry remains open with 'Accepted' status and is reviewed annually. There is no closure for an accepted risk — it remains visible in the register.

Risks are never closed without Information Security Manager confirmation. A Risk Owner cannot unilaterally close a risk in the register. Closed risk entries are retained for 7 years per POL-002.

9. Related Documents

Document ID	Title	Relationship
POL-010	Information Security Risk Policy	Parent policy — this SOP operationalises POL-010
POL-005	System Classification Policy	System tier and regulatory flags are primary inputs to ISRA scope and risk scoring — GxP and SOX flags trigger additional scoring requirements
POL-006	Computer System Validation Policy	System-level risk assessment is a mandatory VMP deliverable (SOP-006 Step 4); residual risks from validation assessments feed the IS Risk Register
POL-007	Change Management Policy	Material changes to Tier 1/GxP systems require a risk assessment update; the SOP-007 change impact assessment references this process
POL-011	Business Continuity Policy	Business Impact Analysis outputs (RTO/RPO, MTPD) inform the availability impact dimension of ISRA risk scoring for Tier 1/2 systems

Document ID	Title	Relationship
POL-012	Incident Response Policy	Post-Incident Reviews generate trigger-based ISRA scope updates; Critical/High risks from incidents are added to IS Risk Register within 5 business days of incident close
POL-013	Third Party and Vendor Risk Policy	Vendor risk assessments (SOP-013) feed into the IS Risk Register as a sub-register; Tier A/B vendor risks are consolidated quarterly
POL-014	Audit Trail and Monitoring Policy	Monitoring alerts and audit trail gaps that indicate systemic risk are escalated to the IS Risk Register
SOP-003	Data Integrity Process	DIRA register is a sub-register of IS Risk Register — Medium+ DIRA findings are consolidated quarterly
SOP-004	Privacy Process	DPIA register is a sub-register of IS Risk Register — High+ DPIA findings are consolidated quarterly
SOP-005	System Classification Process	System Register is the primary asset input for ISRA scope — all Tier 1/2/GxP/SOX systems are in ISRA scope
SOP-006	Computer System Validation Process	System-level risk assessment integrated into SOP-006 validation lifecycle Step 4; VMF receives risk assessment output
SOP-013	Third Party and Vendor Risk Assessment Process	Vendor risk findings consolidated into IS Risk Register quarterly per Section 7.1
EXC-001	Exception Management Policy and Register	High/Critical exceptions feed IS Risk Register; risk acceptance under this SOP is distinct from exception process — acceptance means risk is within appetite, not that a policy requirement is being deviated from
RACI-001	Roles, Responsibilities and Authorities	Accountability for IS risk governance

— End of Document —

SOP-010 v1.0 DRAFT | [Company Name] | INTERNAL USE